APP SECURITY · IDOR

Change one number in the URL.

...and see someone else's order? A 2-minute check for any app with order or profile pages.

Swipe →

WHAT HAPPENS



/orders/1042 → 1041

One number lower, and the page shows another customer's **name, address and phone number**. That's a data leak.

Example data, made up.

WHY



Logged in ≠ allowed.

The app only checks that **someone is logged in**.
It never checks that the order **belongs to them**.
This bug is called IDOR: Insecure Direct Object Reference.

HOW COMMON



The #1 web app risk.

Broken access control, the family IDOR belongs to, is **#1 on the OWASP Top 10:2025**.

OWASP Top 10:2025, A01 Broken Access Control

TEST IT · ONLY ON YOUR OWN APP



Two test accounts.

Open an order with account A. Copy the link and open it as account B.
403 / not allowed = good. **The order loads** = it's open.

Check whose data it is.

```
orders.find({ id,
  userId: user.id })
```

On the server, on **every request**. Unguessable IDs (UUIDs) help, but they don't replace this check.

OWASP IDOR Prevention Cheat Sheet

BUILT YOUR APP WITH AI?

I'll take a look at it.

Send me a message. And follow for more checks like this.